Rogue AI Detection in the Wild

Findings, challenges and insights on detecting and preventing rogue AI agent activity

Whitepaper | 22 October 2026 | Companion to the methods report and the Python prototype

Data notice: the prototype described in this paper runs only on synthetic data generated by the project. No real platform, account or person was scraped or analyzed. Prototype results show that the pipeline works; they are not evidence of real-world detection accuracy.

1. Executive summary

AI agents that act through tools and APIs can be hijacked, misused or deliberately deployed for abuse. Detecting this from outside the systems an organization controls is hard, and the published evidence says no single technique is reliable. This paper summarizes what a review of public sources supports, shows how a small prototype puts those ideas together, and sets out what should be done to prevent rogue AI activity rather than only detect it.

- Layer the defenses. Unsupervised behavioral scoring, graph-based coordination analysis and tool-call monitoring each fail in different ways. Combining them, with human review, performed far better than the Isolation Forest alone in the prototype's synthetic test.
- Score behavior, not intent. Intent cannot be observed. Every flag is a lead for a person, and unsupervised evidence on its own should be capped at low severity until corroborated.
- Prevention beats detection. OWASP and MITRE ATLAS both frame agent harm around tool use, permissions and autonomy. Least privilege, approval for high-impact actions and complete logging reduce what a rogue agent can do and make misuse visible [4][5][7].
- Evasion is easy. The prototype's evasive variants dropped fused recall from 1.00 to 0.11 on synthetic data. Published work also shows that LLM-based detectors can be attacked [10].
- Collection is bounded by law and ethics. US case law has narrowed the CFAA, but contract terms, data protection law and platform rules still apply, so building on synthetic or pseudonymized data should be the default [14][15][16][17].

2. Problem and scope

There is no standard definition of a rogue AI agent. This work uses a working one: an automated, model-driven or model-assisted actor that pursues actions outside its operator's intended or authorized scope, or is operated to cause harm, on systems the detector's owner does not control. It covers two cases that look the same from outside: an agent hijacked through injected instructions, and an agent deliberately deployed for abuse.

The project brief names six components: data collection, anomaly detection, real-time monitoring with alerting, collaboration and intelligence sharing, an ethical and compliance framework including responsible disclosure, and a community engagement platform. The prototype implements each at small scale; the report covers the underlying methods and sources in detail.

3. What the evidence says

3.1 Bot and agent detection

Social bot detection is the most mature neighboring field. Botometer evolved from BotOrNot (2016) toward ensembles of specialized classifiers [8]. Yang et al. found that choosing a subset of training data generalized better across datasets than training on everything [9]. The TwiBot-22 benchmark is a graph with 92,932,326 nodes and 170,185,937 edges [11]. Most of this work targets accounts on one platform; an agent acting through APIs has no public profile to classify. Chan et al. propose agent identifiers, real-time monitoring and activity logs, all of which depend on the deployer's cooperation [12].

LLM-based detectors are an attack surface. Orenstein and Birman report accuracy drops of up to 48 percent from adversarial rewriting and prompt injection against LLM bot detectors, and about 86 percent accuracy for a multi-LLM ensemble under strong attack, on 2,000 TwiBot-20 accounts with three open-source models [10]. This is one group's result on one dataset.

3.2 Anomaly and coordination detection

Isolation Forest isolates anomalies with random splits and is a sensible first-pass detector for per-agent features [13]. Pacheco et al. build coordination networks from shared behavioral traces and link accounts only when their behavior is more similar than chance; they stress that coordination does not imply automation [6]. Meta's definition of coordinated inauthentic behavior is likewise behavior-based rather than content-based [18]. For agent-to-agent collusion, Motwani et al. show that steganographic coordination can evade monitoring and that simple mitigations may be insufficient [19].

3.3 Prompt injection and agent misuse

Greshake et al. demonstrated that instructions placed in retrieved data can steer LLM-integrated applications, with impacts including data theft and code execution [3]. OWASP lists Prompt Injection (LLM01) and Excessive Agency (LLM06) and names excessive functionality, permissions and autonomy as root causes [4]; its agentic list puts Agent Goal Hijack first [5]. NIST treats agent hijacking as a form of indirect prompt injection [20]. Anthropic reported in November 2025 that it disrupted an espionage campaign in which its coding tool performed much of the tactical work; this is the vendor's own account and was not independently verified here [21].

3.4 Standards and frameworks

Framework	Role in this work
MITRE ATLAS [1]	Shared vocabulary; alerts carry approximate technique tags (checked against the v2026.09 data file)
NIST AI RMF and AI 600-1 [2]	Governance functions (govern, map, measure, manage) and the generative AI profile
OWASP LLM and Agentic Top 10 [4][5]	Misuse patterns and mitigations
STIX 2.1 and TAXII 2.1 [22]	Structured sharing of indicators; the prototype exports STIX
ISO/IEC 29147 and CERT/CC CVD [23]	Template for a disclosure process
EU AI Act Article 73 [24]	Serious-incident reporting for high-risk AI providers; Annex III rules apply from 2 December 2027 after the Digital

	Omnibus

4. The prototype

The prototype is a Python application with a command line and a local web dashboard. It uses only synthetic events generated by the project; its network collector is intentionally disabled. It implements:

- A collector interface with a synthetic generator, a validated and PII-redacting importer for community-contributed files, and the disabled live stub.
- Per-agent feature extraction (timing, access, tool use, content and network features).
- Isolation Forest scoring with per-agent explanations, transparent rules keyed to technical gates (denied or out-of-scope requests, new external-destination tool use after reading external content, encoded payloads), and a coordination graph combining timing synchrony, rare-template content similarity and reciprocal messaging.
- A hash-chained alert log with severity, explanation and approximate ATLAS tags; a sliding-window monitor; flagged-case evidence packages; STIX 2.1 export; a community report form; and developer and disclosure documents.

The synthetic data plants three rogue roles (an access prober, a five-agent collusion ring and two injection-driven hijacks) among 53 benign agents, including look-alikes that should not be escalated: scheduled jobs, a heavy crawler, an orchestrator with workers, and routine users of an external tool. The roles are planted by the same author as the detectors, so the results below are a regression check, not a benchmark.

Synthetic run (seed 7, 62 agents, 9 rogue)	**Precision**	**Recall**	**Notes**
Fused pipeline, standard scenarios	1.00	1.00	No benign look-alike escalated above info or low
Isolation Forest alone, standard	0.62	0.56	Flags scheduled jobs and the heavy crawler; misses most of the collusion ring
Fused pipeline, stealth variant	1.00	0.11	1 of 9 found; slow probing, de-synchronized ring and a routine-tool hijack evade
Isolation Forest alone, stealth	0.25	0.22	Mostly false positives

Test status: 42 automated tests pass (Python 3.13.5, scikit-learn 1.9.1, numpy 2.5.4, networkx 3.7), covering schema and collectors, features, detectors, the pipeline on several seeds, alert-log tamper detection, the STIX export, report validation and the web endpoints. The documented install and run steps were also checked in a clean virtual environment.

What the prototype shows, and does not

- Shows: that independent evidence types can be fused into explained alerts, that benign periodic or orchestrated behavior can be handled explicitly, and that evasions are easy to plant and expected to work.

- Does not show: performance on real traffic, behavior under drift, or resistance to adaptive attackers. No such claim is made.

5. Challenges

Challenge	Why it matters
Intent and attribution	Behavior can be anomalous for benign reasons; a flag is not proof, and naming an operator wrongly causes real harm.
Evasion and adaptation	Adversarial rewriting, slow-and-low activity, and abuse of already-granted tools defeat simple detectors.
No external agent identity	Outside a deployer's own systems there is no agreed way to identify an AI agent or obtain its logs [12].
Labeled data	Little public labeled data exists for agent-to-agent misconduct; benchmarks such as TwiBot-22 are social-platform specific and gated [11].
Benign look-alikes	Schedulers, crawlers and orchestrators are unusual or synchronized too. Fan-out workloads triggered by one cause can look like coordination.
Detector drift and attack surface	LLM-based detectors can be attacked and can change as models are updated [10].
Legal and privacy limits	Collection must respect terms, data protection law and platform rules; EU platform data has a formal researcher route [14][15][16][17].
Human workload	Alert fatigue and the cost of review limit how aggressive thresholds can be.

6. Preventing rogue AI activity

Detection from outside is a backstop. The larger gains come from controls on the systems that host agents:

- Least privilege. Give each agent only the tools, data and permissions its task needs; avoid open-ended tools; run actions in the requesting user's context [4].
- Approval for high-impact actions. Require a human or independent check for deletion, external sends and privilege changes [4].
- Treat external content as untrusted. Retrieved pages, files and tool outputs can carry instructions; monitor for goal changes after ingestion [3][5].
- Identity and logging. Assign agent identifiers and keep tamper-evident activity logs so misuse can be attributed and investigated [12].
- Baseline and alert on tool-call sequences. Behavioral deviation (a new external-destination tool after reading external content) is more robust than content filtering.
- Incident process. Prepare detection, investigation, correction and reporting workflows, including obligations such as AI Act Article 73 where they apply [24].
- Share carefully. Exchange indicators in structured form with partners, after review and with personal data removed [22][23].

7. Ethics, legal constraints and responsible disclosure

Four sources set the boundaries most relevant to data collection. This is a research summary, not legal advice.

Source	Constraint	Design consequence
Van Buren v. United States (2021) [14]	CFAA 'exceeds authorized access' means entering areas one is barred from, not misusing allowed access	Define unauthorized access by technical gates; never bypass controls
hiQ v. LinkedIn (9th Cir. 2022) [15]	Upheld a preliminary injunction; CFAA likely does not reach public pages; no final merits ruling	Public-page collection has support in that circuit; other claims remain
Meta v. Bright Data (N.D. Cal. 2024) [16]	Contract claim failed on logged-off scraping of public data	Read each platform's terms; logged-in access is governed by them
EDPB Guidelines 03/2026 (draft) [17]	Scraping for generative AI training: minimize, consider synthetic data, exclude sites that oppose scraping	Scope is AI training by private entities; apply by analogy. Prefer synthetic or pseudonymized data

The Menlo Report's four principles (respect for persons, beneficence, justice, and respect for law and public interest) frame the project policy [25]. The project ships a collector compliance checklist and responsible disclosure guidelines adapted from coordinated vulnerability disclosure practice: report privately first, state confidence honestly, give the operator a route to dispute, and publish only aggregate lessons.

8. Recommendations

Near term

- Adopt the collector checklist and keep all development on synthetic or pseudonymized data until legal and ethics review is complete.
- Instrument agents you operate with identifiers, scoped credentials and tool-call logs, and feed them to the detectors.
- Extend the evaluation with adversarial and benign-look-alike cases, and report false positives and review workload alongside detection rates.

Medium term

- Build partnerships with security researchers and academic groups for labeled data and independent validation; use sanctioned data-access routes for platform data.
- Stand up a disclosure program with a published contact, dispute path and partner review before sharing indicators.
- Add drift monitoring and retraining on reviewed windows; test detectors against adaptive attackers.

Open research questions

- An accepted external identity for AI agents.
- Public labeled data for agent-to-agent misconduct.
- Whether communication monitoring can catch steganographic collusion.

9. Limitations of this paper

- The sources were gathered by web search; a few primary documents were read in full (the EDPB draft guidelines, the arXiv paper on LLM bot detectors, and the ATLAS v2026.09 data file). Others rest on abstracts or summaries and should be checked before being cited onward.
- Several 2026 items are recent and may change, including the EDPB draft guidelines, ATLAS v2026.09 and the EU Digital Omnibus changes.
- Company reports (Anthropic, Meta) are self-reported.
- Prototype results are on synthetic data planted by the authors and do not measure real-world performance.

References

[1] MITRE ATLAS. https://atlas.mitre.org/ ; data file v2026.09: https://github.com/mitre-atlas/atlas-data/blob/main/dist/v6/ATLAS-2026.09.yaml

[2] NIST. AI Risk Management Framework (released 26 Jan 2023): https://www.nist.gov/itl/ai-risk-management-framework ; NIST AI 600-1, Generative AI Profile (26 Jul 2024): https://doi.org/10.6028/NIST.AI.600-1

[3] Greshake, K. et al. Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. arXiv:2302.12173. https://arxiv.org/abs/2302.12173

[4] OWASP. Top 10 for LLM Applications 2025: LLM01 Prompt Injection https://genai.owasp.org/llmrisk/llm01-prompt-injection/ ; LLM06 Excessive Agency https://genai.owasp.org/llmrisk/llm062025-excessive-agency/

[5] OWASP. Top 10 for Agentic Applications. https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai/

[6] Pacheco, D. et al. Uncovering Coordinated Networks on Social Media: Methods and Case Studies. ICWSM 2021. https://doi.org/10.1609/icwsm.v15i1.18075

[7] MITRE ATLAS technique entries AML.T0051 (LLM Prompt Injection), AML.T0053 (AI Agent Tool Invocation), AML.T0080 (AI Agent Context Poisoning), AML.T0086 (Exfiltration via AI Agent Tool Invocation) and AML.T0118 (Autonomous AI Agent Communication), data file v2026.09, as [1].

[8] Davis, C. et al. BotOrNot (2016) and Botometer versions, as described at https://github.com/osome-iu/botometer-python

[9] Yang, K.-C., Varol, O., Hui, P.-M., Menczer, F. Scalable and Generalizable Social Bot Detection through Data Selection. AAAI 2020. https://ojs.aaai.org/index.php/AAAI/article/view/5460/5316

[10] Orenstein, N., Birman, Y. Breaking and Defending LLM-Powered Social Media Bot Detection Systems. arXiv:2608.15893 (16 Aug 2026). https://arxiv.org/abs/2608.15893

[11] Feng, S. et al. TwiBot-22: Towards Graph-Based Twitter Bot Detection. NeurIPS 2022 Datasets and Benchmarks. https://arxiv.org/abs/2206.04564

[12] Chan, A. et al. Visibility into AI Agents. ACM FAccT 2024. https://arxiv.org/abs/2401.13138

[13] Liu, F. T., Ting, K. M., Zhou, Z.-H. Isolation Forest. IEEE ICDM 2008. https://doi.org/10.1109/icdm.2008.17

[14] Van Buren v. United States, 593 U.S. ___ (2021). https://www.law.cornell.edu/supremecourt/text/19-783

[15] hiQ Labs, Inc. v. LinkedIn Corp., 31 F.4th 1180 (9th Cir. 2022). https://cdn.ca9.uscourts.gov/datastore/opinions/2022/04/18/17-16783.pdf

[16] Meta Platforms, Inc. v. Bright Data Ltd. (N.D. Cal., summary judgment 23 Jan 2024), as reported at https://arstechnica.com/tech-policy/2024/01/facebook-suffers-big-loss-in-lawsuit-against-data-scraping-company/

[17] EDPB. Guidelines 03/2026 on web scraping in the context of generative AI, version 1.0 adopted 7 July 2026 for public consultation. https://www.edpb.europa.eu/system/files/2026-07/edpb_guidelines_2020603_webscraping_v1_en_0.pdf. Also: Digital Services Act Article 40 and Delegated Regulation (EU) 2025/2050 on researcher data access: https://digital-strategy.ec.europa.eu/en/news/commission-adopts-delegated-act-data-access-under-digital-services-act

[18] Meta. Inauthentic Behavior policy (coordinated inauthentic behavior). https://transparency.meta.com/policies/community-standards/inauthentic-behavior/

[19] Motwani, S. R. et al. Secret Collusion among AI Agents: Multi-Agent Deception via Steganography. NeurIPS 2024. https://arxiv.org/abs/2402.07510

[20] NIST. Technical Blog: Strengthening AI Agent Hijacking Evaluations (Jan 2025). https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluations ; NIST AI 100-2 E2025: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-2e2025.pdf

[21] Anthropic. Disrupting an AI-orchestrated cyber espionage campaign. https://www.anthropic.com/news/disrupting-AI-espionage

[22] OASIS. STIX 2.1 https://www.oasis-open.org/standard/stix2-1/ ; TAXII 2.1 https://www.oasis-open.org/standard/taxii2-1/ ; MISP https://www.misp-project.org/

[23] ISO/IEC 29147:2018 https://www.iso.org/standard/72311.html ; CERT Guide to Coordinated Vulnerability Disclosure https://certcc.github.io/CERT-Guide-to-CVD/ ; CISA CVD program https://www.cisa.gov/resources-tools/programs/coordinated-vulnerability-disclosure-cvd-program

[24] EU AI Act, Article 73 (serious incidents) https://www.euaiact.com/article/73 ; implementation timeline (Commission AI Act Service Desk) https://ai-act-service-desk.ec.europa.eu/en/ai-act/timeline/timeline-implementation-eu-ai-act

[25] The Menlo Report: Ethical Principles Guiding Information and Communication Technology Research (DHS, 2012). https://www.dhs.gov/sites/default/files/publications/CSD-MenloPrinciplesCORE-20120803_1.pdf